

INFO ASSURANCE MIDTERMS REVIEWER

Multiple Choice

IoT - network connectivity and computing capability to extend it to objects

Four Layered Archi for IoT

1. **Sensing Layer** – interface between physical and cyber world
2. **Networking Layer** – provides networking support
3. **Service Layer** – middleware
4. **Interface Layer** – interface to integrate service to users

Capability-Based Access Control (CapBAC) - user sends an access request with details

- **Policy Decision Point (PDP)** - checks the request against stored policies, if approved it issues capability ticket
- **Capability Token** – used to directly access resources
- **Principle of Least Authority (PoLA)** - only get the minimum access needed.

Access-Based Access Control (ABAC) – policy-based access control, user sends a request to access a resource

Central policy system - evaluates the request

Main Components of ABAC

- **Subject** – user requesting access
- **Object** – resource being accessed
- **Attributes** – characteristics
- **Policies** – rules defining access
- **Permissions** – allowed actions

Malicious Software (Malware) - software designed to harm systems

Types of Malware

- **Virus** – attached to files
- **Worms** – self-replicating programs
- **Trojans** – disguised as legitimate programs
- **Ransomware** – encrypts files
- **Spyware** – collects sensitive information
- **Adware** – unwanted ads
- **Rootkits** – hides malware

Malware can spread through various channels:

- **Phishing** - Malicious emails
- **Infected Websites** - Websites can spread malware
- **USB Drives** - spread through infected USB
- **Social Engineering** - Attackers may use manipulation

Countermeasures Against Malware

- **Antivirus Software** - detect and remove malware
- **Regular Software Updates** - security patches
- **Firewalls** - barrier between computer and threats
- **Strong Passwords and Multi-Factor Authentication (MFA)** - additional security layers

Classes of Cyber Attacks

- **Network Attacks** - Eavesdropping and Sniffing, Man-in-the-Middle (MitM), Denial-of-Service (DoS)
- **Application Attacks** - SQL Injection (SQLi), Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF)
- **Social Engineering Attacks** – Phishing, Pretexting, Baiting
- **Hardware and Physical Attacks** - Keyloggers, Insider threats, Sabotage

Business Continuity Planning (BCP) - process of creating strategies

Disaster Recovery Planning (DRP) - dealing with technical aspects like recovery sites

The Four Steps of the BCP Process

1. **Project Scope and Planning** - Define the scope and objectives
2. **Business Impact Analysis (BIA)** - Identify critical business functions
3. **Continuity Planning** - Develop detailed plans
4. **Approval and Implementation** - Obtain approval for the plan

Key BIA Metrics

- Maximum Tolerable Downtime (MTD)
- Recovery Time Objective (RTO)

- Recovery Point Objective (RPO)
- Asset Value (AV), ARO, SLE, ALE

Two Main types of analyses used in BIA

1. **Quantitative Impact Assessment** - numerical data and formulas
2. **Qualitative Impact Assessment** - non-numerical factors

Identification

Noise - raw facts with unknown coding

Data - raw facts with known coding

Information - processed data

Knowledge - accepted facts

Information Assurance - study of how to protect you information assets

5 core IA objectives

1. **Availability** - timely
2. **Integrity** - protection
3. **Confidentiality** - info is not disclosed
4. **Authentication** - security measures for validity
5. **Non-repudiation** - sender is provided with proof of a data

Assets - resource being protected

- **Physical Assets** - devices
- **Logical Assets** - Information, data
- **System Assets** - software

Object - item being protected

Subject - entities

Actions - Operations

Examples of Threats under Assets

- **Interruption** - asset becomes unusable
- **Interception** - unauthorized gains access to information assets
- **Modification** - unauthorized tampers with an asset.
- **Fabrication** - asset has been counterfeit.

Vulnerability - weakness in a system

Exploit - method for taking advantage

Dangling Vulnerability - no known threat

Dangling Threat - does not pose a danger, can't do damage

Attack - attempt to gain access

Attack Surface - set of ways that can enter a system

- **Passive Attack** - attacker observes
- **Active Attack** - directly interacts with system
- **Unintentional Attack** - no goal of misuse
- **Attack Subject** - active entity interacts with system
- **Attack Object** - targeted info asset

Exposure - system is vulnerable

Compromise - attacker has succeeded.

Indicator - recognized action

Consequence - outcome of an attack

Risk - possible threat may impact the system

Risk Management - identify and addresses risk

Trust - provide a basis for confidence

- **Trust Mechanism** - security features that provides enforcement
- **Trusted Computing Base (TCB)** - collection of trust mechanisms
- **Assurance** - measure of confidence
- **Trust Management** - unified approach of conceptualizing

Lifecycle - process that asset is managed from arrival

- **Waterfall Model** - process is divided into stages
- **Lifecycle Management** - project managers ensure that right info assurance are incorporated in a system

Enumeration

5 primitives for the Network of Things (NoT)

1. Sensors
2. Aggregators
3. Communication Channel
4. External Utilities
5. Decision Triggers

4 Security Domains in Debra Hermann's Model

1. **Physical Security** - protection of hardware, software

2. **Personnel Security** – variety of ongoing measures
3. **IT Security** – technical features and functions
4. **Operational Security** - operational security procedures

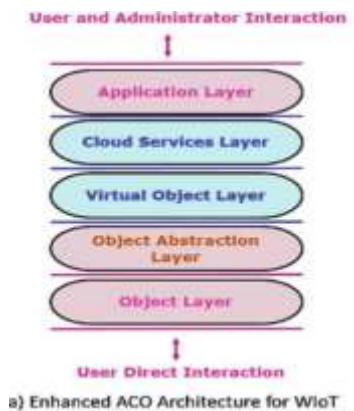
4 basic cloud deployment models.

1. Public Cloud
2. Private Cloud
3. Hybrid Cloud
4. Community Cloud

4 Risk Treatments

1. **Risk Acceptance** – risk is not avoided
2. **Risk Avoidance** – not performing an activity
3. **Risk Mitigation** – taking actions to reduce risk
4. **Risk Transfer** – shift the risk to others

Essay/Illustration



Classes of Cyber Attacks

